1. Introduction et Objectifs

L'objectif de ce TP est de mettre en place une plateforme de supervision SIEM (Security Information and Event Management) utilisant la solution open-source Wazuh. L'idée est de centraliser les logs provenant de différentes sources (Linux, Windows, réseau) pour obtenir une visibilité complète sur les menaces.

2. Déploiement de l'Infrastructure

2.1 Installation du Serveur Wazuh

Le serveur a été installé sur une machine Ubuntu 22.04 (4 Go RAM, 2 cœurs). L'installation automatisée a déployé :

Wazuh Server : Le moteur d'analyse.

Elasticsearch : Pour le stockage et l'indexation des logs.

Kibana (Wazuh Dashboard) : L'interface de visualisation.

2.2 Installation des Agents

Des agents ont été déployés sur deux cibles :

Ubuntu : Installation via le paquet .deb et configuration du fichier /var/ossec/etc/ossec.conf avec l'IP du serveur.

Windows : Installation via l'exécutable officiel en renseignant l'IP du serveur Wazuh.

3. Simulations d'Attaques et Analyse

3.1 Création d'utilisateur (Linux & Windows)

Action : Exécution de sudo adduser testintrusion sur Linux et net user hacker Password123! /add sur Windows.

Observation : Wazuh a immédiatement généré une alerte de niveau élevé concernant la création d'un nouvel utilisateur, ce qui est une technique persistante classique.

3.2 Surveillance de l'intégrité des fichiers (FIM)

Action : Modification du fichier critique /etc/passwd.

Observation : Grâce au module FIM, Wazuh a détecté la modification en temps réel. Cela permet de voir si un attaquant tente de modifier des configurations système.

3.3 Corrélation avec une attaque réseau

Action : Scan de ports via nmap -sS 192.168.1.10 depuis Kali Linux.

Observation : On observe ici la corrélation. Suricata (IDS) détecte le scan réseau, tandis que Wazuh remonte les logs système. L'analyste peut ainsi voir : Qui (IP Kali), Quelle machine (Cible), et Quelle action (Scan + modification de compte).

4. Concepts Clés du SIEM

Le rôle d'un SIEM

Un SIEM sert de "cerveau" central pour la sécurité. Son rôle est de :

Collecter : Récupérer les logs de partout (serveurs, pare-feu, agents).

Normaliser : Mettre tous les logs dans un format lisible et commun.

Corréler : Lier des événements isolés (ex: un scan réseau suivi d'un login raté) pour identifier une attaque complexe.

Alerter : Notifier l'analyste uniquement sur les événements critiques.

Collecte et Corrélation des logs

La collecte se fait via les Agents Wazuh installés sur les machines. La corrélation se fait par des règles. Si l'événement A et l'événement B se produisent dans un laps de temps court, le SIEM déclenche une alerte de "suspicion d'attaque".

5. Améliorations Proposées

Pour renforcer cette infrastructure de supervision, je propose :

Intégration poussée de Suricata dans Wazuh : Envoyer les fichiers eve.json de Suricata directement vers l'agent Wazuh pour centraliser les alertes IDS dans le tableau de bord unique.

Création de règles personnalisées : Définir des alertes spécifiques pour des fichiers métiers critiques (ex: base de données clients).

Ajout de sources externes : Intégrer les logs du pare-feu pfSense pour surveiller les tentatives d'intrusion périmétriques.

Réponse active : Configurer Wazuh pour qu'il bloque automatiquement (via le firewall local) une IP qui tente de forcer un mot de passe SSH après 5 échecs.

Conclusion

Ce TP a permis de simuler le quotidien d'un analyste SOC. La puissance de Wazuh réside dans sa capacité à transformer des milliers de lignes de logs illisibles en une vision claire de la menace, permettant une réaction rapide et précise.